CYBR 437 Secure Coding

Fall 2026

Lab - 7

Release date: November 5, 2026

Due date: November 12, 2026, at 11:59 pm

Introduction

In this lab, you will gain hands-on experience analyzing binaries and exploiting buffer overflow vulnerabilities with return-oriented programming. In it, you will continue to build on your experience analyzing 32-bit and 64-bit binaries to exploit buffer overflow vulnerabilities while chaining multiple return addresses to call functions in sequence.

Setup

- A lab7 tarball is available for download from the Lab-7 assignment page, within it are 3 binary files `task1, task2,` and `task3`.
- Upload the tarball to your VM and untar with the following commands:
  - `scp ./lab7.tar.gz [username]@[ip]:./[directory]`
  - `tar -xzvf lab7.tar.gz`
  - Make the binaries executable with `chmod +x <filename>`

Tasks

Task 1 (25 points)

Analyze the binary `task1` to find the user-defined functions and how (or whether) they are called. Build your exploit to follow the required program flow to print the FLAG, followed by a clean exit from the program.

Task 2 (25 points)

This challenge extends your ROP experience by requiring you to utilize multiple rop gadgets in the correct sequence to satisfy the parameter checks within the functions to print the FLAG in `task2`. Ensure that the program exits cleanly.

Task 3 (25 points)

This challenge will require you to use what you've learned from the previous tasks. Using a rop chain, call multiple functions while satisfying the required checks. Each function should be executed in the correct order to satisfy the program's (`task3`) conditions to print the FLAG. Ensure that the program exits cleanly.

Submission Instructions

Your write-up submission should include:

- For every problem, screen captures demonstrating:
  - Checking the binary file's endianness with the `file` command.
  - Checking which defenses have been turned on/off with `checksec`.
  - The use of pwndbg to illustrate how you arrived at the required value or the eip.
  - Your success in each task (screenshots should include the entire output).
- Detailed explanations of how you performed each buffer overflow attack, including tools and techniques used.